

Guion de demostración del laboratorio P2

Axel Enrique Vasquez Peña | Matrícula 2024-2388 | Duración objetivo 9 minutos

Muestra rostro, voz, fecha y hora. FortiGate se demuestra por GUI. Abre las ventanas antes de grabar, confirma que las VM estén encendidas y que no haya cuarentena activa. No muestres secretos.

0 min 00 s a 0 min 35 s Introducción

En pantalla: Muestra fecha, hora y topología.

“Mi nombre es Axel Enrique Vasquez Peña, matrícula 2024-2388. Esta práctica separa usuarios, servidor web y base de datos mediante VLAN. FortiGate controla la comunicación y aplica perfiles de seguridad.”

0 min 35 s a 1 min 25 s Segmentación

En pantalla: Muestra interfaces y DHCP en GUI, y VLAN y seguridad en el switch.

“Usuarios está en VLAN 10, red 10.23.88.0/25, con DHCP. WEB tiene 10.23.88.130 y DB 10.23.88.146 en subredes /28 separadas. El switch las transporta por un trunk. Los puertos de equipos usan port security, sticky y BPDU Guard. Las nubes conectan administración e Internet.”

1 min 25 s a 2 min 15 s Políticas

En pantalla: Muestra políticas, ruta y NAT. Declara el estado real de las excepciones temporales.

“La primera política permite Usuarios hacia WEB por 443. La segunda bloquea Usuarios hacia DB por 3306. WEB tiene una regla específica para MariaDB por 3306. La WAN utiliza el gateway 192.168.1.1 y NAT en la política de actualizaciones.”

2 min 15 s a 3 min 00 s Acceso y bloqueo

En pantalla: Abre el catálogo HTTPS en Kali y la prueba de DB3306 con su log.

“El catálogo muestra productos consultados en MariaDB por WEB. Desde Usuarios, el acceso directo a DB por 3306 es denegado, como muestra el registro.”

3 min 00 s a 3 min 35 s Alcance HTTPS

En pantalla: Muestra estado de SSL Inspection y error del certificado.

“El servidor ofrece HTTPS, pero no he validado inspección profunda del contenido cifrado. La evaluación rechaza el certificado y solicité una licencia completa. Las pruebas de IPS y archivos siguientes usan HTTP y no las presento como inspección HTTPS.”

3 min 35 s a 4 min 30 s File Filter

En pantalla: Muestra regla, control.txt, descarga de putty.exe y registro.

“El texto de control está permitido. El ejecutable legítimo se identifica como exe y File Filter lo bloquea. El registro muestra el archivo, la regla Bloquear_EXE_HTTP y blocked. No es necesario ejecutar el archivo.”

4 min 30 s a 5 min 10 s Application Control

En pantalla: Muestra perfil y evento de Firefox.

“Application Control reconoce HTTP.BROWSER_Firefox. pass corresponde a Monitor: registra sin bloquear navegación. El bloqueo del ejecutable lo realiza File Filter.”

5 min 10 s a 6 min 15 s DoS

En pantalla: Muestra política y umbral final; prueba acotada y registro. Verifica recuperación.

“La política detecta una tasa elevada de SYN hacia WEB:443. Aparece tcp_syn_flood con clear_session. El umbral se eligió para laboratorio y no es una recomendación de producción.”

6 min 15 s a 7 min 25 s IPS y cuarentena

En pantalla: Muestra sensor, patrón HTTP, log y petición normal bloqueada.

“HTTP.Header.SQL.Injection detecta la cabecera de prueba. El firewall registra y aplica cuarentena de cinco minutos. Una solicitud normal desde el origen recibe la página de bloqueo. La prueba demuestra detección del patrón; no una explotación de la base de datos.”

7 min 25 s a 8 min 20 s Recuperación

En pantalla: Muestra evidencia previa como tal, o un corte señalado con hora antes y después.

“Después de cinco minutos sin repetir el patrón, el catálogo vuelve a responder. Esta evidencia corresponde a la recuperación de la cuarentena.”

8 min 20 s a 9 min 00 s Cierre

En pantalla: Muestra repositorio, documentación y archivos sanitizados.

“El repositorio reúne topología, direccionamiento, comandos y evidencias. Se demostraron segmentación, IPS por HTTP, cuarentena, filtrado de ejecutables, identificación de Firefox y protección SYN. La inspección profunda HTTPS sigue pendiente y está documentada.”

Comprobaciones finales

Realiza File Filter antes de cuarentena. No presentes eventos antiguos como nuevos. HTTP 200 puede contener una página de bloqueo: revisa el cuerpo. No simules una espera continua si editaste el video. No afirmes acceso exclusivo WEB a DB si siguen activas excepciones de actualización.

Duración menor de diez minutos. Enlace del video al principio del README. Configuraciones sin secretos. TXT con enlaces y nombre exigido. Comprueba acceso a video y repositorio.